

# Содержание

1 Отчёт по CVE в Ozone — таблица эксплуатируемости (скан cve\_oz.md)

1.1 Пояснения по эксплуатируемости

E1 — Клиентский коннектор файловой системы, не на classpath ни одного сер-  
вера.

E2 — Межузловой транспорт Ratis (shaded netty), только «сервер-сервер».

E3 — HTTP веб-интерфейс (Jetty), включён по умолчанию.

E4 — Разбор protobuf/netty в RPC/gRPC Ozone.

E5 — Плагин Ranger: только на OM, за флагом авторизации.

E6 — Уязвимый примитив никогда не выбирается (фантомный CRITICAL).

E7 — spring в Ozone — только spring-jdbc/jOOQ (Recon).

E8 — Клиентский TLS-MITM; Ozone не запускает Thrift-сервер.

E9 — Локальный доступ либо опциональный/внутрикластерный компонент.

E10 — MITM на пути DNS, только внутри кластера; исправление заблокировано.

E11 — Недоверенный вход не доходит до уязвимого парсера.

E12 — Разбор JWT, только если настроена JWT-аутентификация.

1.2 Итог

1

4

4

4

5

5

5

5

5

5

6

6

6

## 1 Отчёт по CVE в Ozone — таблица эксплуатируемости (скан cve\_oz.md)

**Дата:** 8 сентября 2026 · **Объект:** образ Ozone 1.4.1.13.079 · **Сверено с:** репозиторий SDPOZN-2805-fix-cve-issues + плагин Ranger component-ranger-plugins · **Входные дан-  
ные:** ~/sdp/component-ozone/cve\_oz.md

Одна строка на просканированную библиотеку. **Приоритет** объединяет статус *исправле-  
ния* и приоритет *устранения* (см. легенду), а столбец **Эксплуат.** даёт вердикт о достижи-  
мости, общие пояснения к которому вынесены в сноски **E1-E12** ниже. Ozone — это много-  
сервисный дистрибутив (OM, SCM, Datanode, Recon, S3 Gateway, httpfs), поэтому достижи-  
мость определяется по classpath каждого сервиса, что сверено с дескрипторами classpath  
дистрибутива.

**Скан относится к более старой сборке 1.4.1.13.079, которая предшеству-  
ет большинству исправлений этой сессии.** На текущей ветке: bcprov 1.84,  
netty 4.1.137, ratis-thirdparty 1.1.0, protobuf → 3.25.5, jackson 2.18.9, spring 5.3.39;  
а в component-ranger-plugins: Elasticsearch → 7.17.29 и исправление песочницы  
Nashorn. Они помечены ✓ — **пересборка образа их закрывает.**

**Легенда приоритетов** — ✓ уже исправлено на ветке / в репозитории Ranger (закрывается  
пересборкой) · **P2** ещё открыто и достижимо на поверхности по умолчанию (действовать)  
· **P3** ещё открыто, но не эксплуатируется в текущем развёртывании (клиентская сторона  
/ за флагом авторизации / внутри кластера / исправление заблокировано вышестоящей  
зависимостью — подавить или обновить при случае).

| Библиотека (jar ·<br>контейнер)                         | CVE                                                                                                       | Приоритет            | Эксплуат. |
|---------------------------------------------------------|-----------------------------------------------------------------------------------------------------------|----------------------|-----------|
| bcprov-jdk18on 1.77                                     | CVE-2025-14813,<br>CVE-2024-34447,<br>CVE-2024-30172,<br>CVE-2024-30171,<br>CVE-2024-29857                | ✓ (1.84)             | E6        |
| protobuf-java 3.7.1 ·<br>hadoop-shaded-<br>protobuf_3_7 | CVE-2024-7254,<br>CVE-2022-3510,<br>CVE-2022-3509,<br>CVE-2022-3171,<br>CVE-2021-22570,<br>CVE-2021-22569 | ✓ (→ _3_25 / 3.25.5) | E4        |
| protobuf-java 3.19.6                                    | CVE-2024-7254                                                                                             | ✓ (3.25.5)           | E4        |

| Библиотека (jar · контейнер)                              | CVE                                                                                                                                                                                                                                                                                      | Приоритет           | Эксплуат. |
|-----------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------|-----------|
| protobuf-java 2.5.0                                       | CVE-2024-7254,<br>CVE-2022-3171,<br>CVE-2021-22570,<br>CVE-2021-22569                                                                                                                                                                                                                    | ✓ (→ 3.25.5)        | E4        |
| netty-codec 4.1.128                                       | CVE-2026-59901,<br>CVE-2026-42583                                                                                                                                                                                                                                                        | ✓ (4.1.137)         | E4        |
| netty-codec-http 4.1.128                                  | CVE-2026-56745,<br>CVE-2026-55833,<br>CVE-2026-55831,<br>CVE-2026-42587,<br>CVE-2026-42584,<br>CVE-2026-33870,<br>CVE-2026-59921,<br>CVE-2026-59903,<br>CVE-2026-56746,<br>CVE-2026-50020,<br>CVE-2026-42585,<br>CVE-2026-42581,<br>CVE-2026-42580,<br>CVE-2026-41417,<br>CVE-2025-67735 | ✓ (4.1.137)         | E4        |
| netty-codec-http2 4.1.128                                 | CVE-2026-56819,<br>CVE-2026-42587,<br>CVE-2026-33871,<br>CVE-2026-50560,<br>CVE-2026-48043,<br>CVE-2026-47244                                                                                                                                                                            | ✓ (4.1.137)         | E4        |
| netty-handler 4.1.128                                     | CVE-2026-50010,<br>CVE-2026-45416,<br>CVE-2026-44249                                                                                                                                                                                                                                     | ✓ (4.1.137)         | E4        |
| netty-codec-dns 4.1.100 ·<br>ratis-thirdparty-misc        | CVE-2026-42579,<br>CVE-2026-73508                                                                                                                                                                                                                                                        | ✓ (1.1.0)           | E2        |
| netty-codec-http2 4.1.100 ·<br>ratis-thirdparty-misc      | CVE-2026-56819,<br>CVE-2026-42587,<br>CVE-2026-33871,<br>CVE-2025-55163,<br>CVE-2026-50560,<br>CVE-2026-48043,<br>CVE-2026-47244                                                                                                                                                         | ✓ (1.1.0)           | E2        |
| ranger-plugins-common 2.4.0 ·<br>ranger-ozone-plugin-impl | CVE-2025-59059                                                                                                                                                                                                                                                                           | ✓ (бэкпорт Nashorn) | E5        |
| elasticsearch 7.10.2 ·<br>ranger-ozone-plugin-impl        | CVE-2023-31418,<br>CVE-2025-37731,<br>CVE-2025-37727,<br>CVE-2024-52979,<br>CVE-2024-43709,<br>CVE-2024-23450,<br>CVE-2024-23444,<br>CVE-2023-49921,<br>CVE-2023-46673,<br>CVE-2023-31419,<br>CVE-2023-31417,<br>CVE-2021-22144,<br>CVE-2021-22135,<br>CVE-2021-22134                    | ✓ (7.17.29)         | E5        |

| Библиотека (jar · контейнер)                                  | CVE                                                                                                                                                                                                                                                                            | Приоритет                | Эксплуат. |
|---------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------|-----------|
| elasticsearch-rest-client 7.10.2 · ranger-ozone-plugin-impl   | CVE-2021-22145                                                                                                                                                                                                                                                                 | ✓ (7.17.29)              | E5        |
| spring-core 5.3.27                                            | CVE-2025-41249, CVE-2026-41848                                                                                                                                                                                                                                                 | ✓ (5.3.39)               | E7        |
| jackson-databind 2.15.0 · ozone-filessystem-hadoop2           | CVE-2026-54513, CVE-2026-54512, CVE-2026-59888, CVE-2026-54515, CVE-2026-54514                                                                                                                                                                                                 | ✓ (пересборка → 2.18.9)  | E1        |
| jackson-core 2.15.0 · ozone-filessystem-hadoop3-client        | GHSA-72hv-8253-57qq                                                                                                                                                                                                                                                            | ✓ (пересборка → 2.18.9)  | E1        |
| netty-codec 4.1.100 · ozone-filessystem-hadoop2               | CVE-2026-59901, CVE-2026-42583                                                                                                                                                                                                                                                 | ✓ (пересборка → 4.1.137) | E1        |
| netty-codec-http 4.1.100 · ozone-filessystem-hadoop3-client   | CVE-2026-56745, CVE-2026-55833, CVE-2026-55831, CVE-2026-42587, CVE-2026-42584, CVE-2026-33870, CVE-2026-59921, CVE-2026-59903, CVE-2026-56746, CVE-2026-50020, CVE-2026-42585, CVE-2026-42581, CVE-2026-42580, CVE-2026-41417, CVE-2025-67735, CVE-2024-29025, CVE-2025-58056 | ✓ (пересборка → 4.1.137) | E1        |
| netty-common 4.1.100 · ozone-filessystem-hadoop2              | CVE-2025-25193, CVE-2024-47535                                                                                                                                                                                                                                                 | ✓ (пересборка → 4.1.137) | E1        |
| netty-handler 4.1.100 · ozone-filessystem-hadoop2             | CVE-2026-50010, CVE-2026-45416, CVE-2026-44249, CVE-2025-24970                                                                                                                                                                                                                 | ✓ (пересборка → 4.1.137) | E1        |
| netty-handler-proxy 4.1.128 · ozone-filessystem-hadoop3       | CVE-2026-42578                                                                                                                                                                                                                                                                 | ✓ (пересборка → 4.1.137) | E1        |
| netty-resolver-dns 4.1.100 · ozone-filessystem-hadoop3-client | CVE-2026-47691, CVE-2026-45674, CVE-2026-45673                                                                                                                                                                                                                                 | ✓ (пересборка → 4.1.137) | E1        |
| commons-lang3 3.14.0 · ozone-filessystem-hadoop2              | CVE-2025-48924                                                                                                                                                                                                                                                                 | P3                       | E1        |
| jetty-http 9.4.57                                             | CVE-2026-2332, CVE-2025-11143, CVE-2024-6763                                                                                                                                                                                                                                   | <b>P2</b> · HIGH         | E3        |
| jetty-security 9.4.57                                         | CVE-2026-10050                                                                                                                                                                                                                                                                 | P3 · HIGH                | E3        |
| jetty-server 9.4.57                                           | CVE-2026-6790                                                                                                                                                                                                                                                                  | P3 · MED                 | E3        |
| commons-configuration2 2.10.1                                 | CVE-2026-45205                                                                                                                                                                                                                                                                 | P3 · MED                 | E11       |

| Библиотека (jar · контейнер)                                   | CVE                                                                                                                                            | Приоритет            | Эксплуат. |
|----------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------|----------------------|-----------|
| commons-configuration2 2.8.0 · ranger-ozone-plugin-impl        | CVE-2026-45205, CVE-2024-29133, CVE-2024-29131                                                                                                 | P3 · MED             | E5        |
| commons-lang 2.6 · httpclient 4.5.6 · ranger-ozone-plugin-impl | CVE-2025-48924<br>CVE-2020-13956                                                                                                               | P3 · MED<br>P3 · MED | E11<br>E5 |
| jackson-core 2.11.3 · htrace-core4-shaded (ranger)             | CVE-2025-52999, GHSA-72hv-8253-57qq                                                                                                            | P3 · HIGH            | E5        |
| jackson-databind 2.11.3 · htrace-core4-shaded (ranger)         | CVE-2026-54513, CVE-2026-54512, CVE-2026-50193, CVE-2022-42004, CVE-2022-42003, CVE-2021-46877, CVE-2020-36518, CVE-2026-54515, CVE-2026-54514 | P3 · HIGH            | E5        |
| nimbus-jose-jwt 9.37.2                                         | CVE-2025-53864                                                                                                                                 | P3 · MED             | E12       |
| zookeeper 3.8.4                                                | CVE-2026-24308, CVE-2026-24281                                                                                                                 | P3 · HIGH            | E9        |
| dnsjava 2.1.7                                                  | CVE-2024-25638                                                                                                                                 | P3 · HIGH (заблок.)  | E10       |
| libthrift 0.14.1                                               | CVE-2026-43869                                                                                                                                 | P3 · HIGH            | E8        |
| hadoop-common 3.3.6                                            | CVE-2024-23454                                                                                                                                 | P3 · LOW             | E9        |

## 1.1 Пояснения по эксплуатируемости

### E1 — Клиентский коннектор файловой системы, не на classpath ни одного сервера.

Находка вшита (shaded) в ozone-filesystem-hadoop2/hadoop3/hadoop3-client-\*.jar, которого **нет** ни в одном classpath сервисов Ozone (сверено с дескрипторами classpath дистрибутива). Это отдельные коннекторы o3fs:///ofs:// для внешних клиентов Hadoop/Spark/Hive; серверы Ozone их не загружают. Значимо только для клиентского процесса, использующего коннектор — и при пересборке ветки эти shaded-jar также получают исправленные netty 4.1.137 / jackson 2.18.9 (так что открытыми для этого клиента остаются только commons-lang3 и nimbus, которые на ветке не обновлялись).

### E2 — Межузловой транспорт Ratis (shaded netty), только «сервер-сервер».

Внутри ratis-thirdparty-misc; используется для gRPC-канала консенсуса Ratis между узлами OM/SCM/DN, клиентам Ozone не доступен. **Уже исправлено** на ветке (ratis-thirdparty 1.0.5 → 1.1.0, shaded netty 4.1.136).

### E3 — HTTP веб-интерфейс (Jetty), включён по умолчанию.

Каждый сервис Ozone поднимает Jetty веб-UI/REST-эндпоинт (ozone.om.http.enabled / ozone.scm.http.enabled = true; OM :9874, SCM :9876, Recon :9888, S3G :9878, DN). **CVE-2026-2332** (request smuggling) достижима для любого, кто имеет доступ к веб-порту — это наиболее серьёзная клиентская экспозиция здесь, особенно за service-mesh DropApp. **CVE-2026-10050** (обход digest-аутентификации) **не** достижима: аутентификация HTTP в Ozone — SPNEGO/Kerberos, а не HTTP Digest. **Исправления в OSS-ветке Jetty 9.4 под**

**Java 8 нет** (исправления в 9.4.60/9.4.63 — сборки EOL; Maven Central заканчивается на 9.4.58) — остаётся открытым; митигировать на уровне service-mesh (нормализация chunked-кодирования) либо принять с документированием.

#### **E4 — Разбор protobuf/netty в RPC/gRPC Ozone.**

Hadoop-IPC (protobuf) на OM/SCM/DN и gRPC-транспорт разбирают недоверенные сообщения клиентов — реально на поверхности сервера. **Уже устранено** на ветке: protobuf-java → 3.25.5 (устаревший рантайм proto2, gRPC и hadoop-shaded-protobuf\_3\_7 → \_3\_25), отдельный netty → 4.1.137. Просканированного protobuf-java-2.5.0.jar в текущем дистрибутиве уже нет.

#### **E5 — Плагин Ranger: только на OM, за флагом авторизации.**

Jar-файлы ranger-ozone-plugin-impl/\* загружаются только если оператор задаёт ozone.acl.authorizer.class равным авторизатору Ranger; по умолчанию используется нативный OzoneAccessAuthorizer (ozone.acl.enabled=false). Elasticsearch — только для аудита и **отключён** (XAAUDIT.ELASTICSEARCH.ENABLE=false); RCE через Nashorn в ranger-plugins-common требует управляемых атакующим скриптов политик, которые задаются администратором через сервис Ranger admin; копии httpclient/htrace обращаются к доверенному эндпоинту Ranger admin. **ElasticSearch (→ 7.17.29) и песочница Nashorn уже исправлены** в component-ranger-plugins; остальные CVE вендорских jar (httpclient 4.5.6, htrace-shaded jackson) неактивны, пока Ranger не включён.

#### **E6 — Уязвимый примитив никогда не выбирается (фантомный CRITICAL).**

BouncyCastle присутствует в runtime-classpath (SCM CA, TLS, block-токены), но CVE-2025-14813 — в режиме **GOST 28147 CTR**; Ozone использует стандартные AES/RSA/ECDSA и никогда не выбирает GOST 28147. **Уже исправлено** (bcprov 1.77 → 1.84, что также закрывает CVE-2026-0636/5588).

#### **E7 — spring в Ozone — только spring-jdbc/jOOQ (Recon).**

spring-core на classpath Recon исключительно для jOOQ/JDBC. spring-security @EnableMethodSecurity отсутствует, поэтому у CVE-2025-41249 нет достижимой точки вызова. **Уже обновлён** до 5.3.39 (закрывает прочие CVE spring-core; у CVE-2025-41249 нет OSS-исправления на линии 5.3.x, но она в любом случае недостижима).

#### **E8 — Клиентский TLS-MITM; Ozone не запускает Thrift-сервер.**

libthrift попадает только через jaeger-thrift (трассировка), которая отключена по умолчанию (hdds.tracing.enabled=false), и Ozone **не** запускает Thrift-сервер — libthrift здесь только клиент отправки трасс jaeger. CVE-2026-43869 (CWE-297, отсутствие проверки имени хоста TLS) — слабость клиента при сетевом MITM, поэтому со стороны сервера не эксплуатируется вдвойне.

#### **E9 — Локальный доступ либо опциональный/внутрикластерный компонент.**

hadoop-common CVE-2024-23454 (локальное раскрытие временного файла) требует локального доступа к контейнеру. ZooKeeper присутствует только на classpath **httpfs** — ядро Ozone использует Ratis, а не ZK — и ансамбль ZK является доверенным внутрикластерным сервисом; достижимо только при развёртывании httpfs против доступного атакующему ZooKeeper. Обновить ZK → 3.8.6 при случае.

#### **E10 — MITM на пути DNS, только внутри кластера; исправление заблокировано.**

Обход DNSSEC в dnsjava требует атакующего на пути DNS; разрешение имён происходит внутри кластера. Исправление **заблокировано вышестоящей зависимостью**: dnsjava 3.x меняет ResolverConfig.searchPath() несовместимо с SecurityUtil\$QualifiedHostResolver

из `hadoop-common` 3.3.6, поэтому требуется Hadoop 3.4.x (прежний откат SDPOZN-2492 упёрся ровно в это).

### E11 — Недоверенный вход не доходит до уязвимого парсера.

CVE в `commons-configuration2` / `commons-lang` / `commons-lang3` — это ошибки DoS/неконтролируемой рекурсии, требующие управляемого атакующим входа в конкретный парсер/метод; Ozone разбирает собственную доверенную конфигурацию. Обновить при случае (`commons-configuration2` → 2.15.0, `commons-lang3` → 3.18.0) — низкая срочность.

### E12 — Разбор JWT, только если настроена JWT-аутентификация.

`nimbus-jose-jwt` CVE-2025-53864 (DoS через глубоко вложенный JSON) достижима только при включённой JWT-аутентификации на S3G/OM, что не является настройкой по умолчанию (Kerberos / секрет S3). Обновить до 9.37.4 при случае; остаётся открытым.

---

## 1.2 Итог

- **Пересобрать образ.** Скан относится к устаревшей сборке 1.4.1.13.079; CRITICAL и подавляющее большинство HIGH-находок — `bcprov`, весь `protobuf`, весь `netty` (отдельный / `ratis` / `shaded` в `fs-jar`), `jackson` (сервер + пересобранные `fs-jar`), `spring`, а также `ElasticSearch` и RCE через `Nashorn` в `component-ranger-plugins` — **уже исправлены** на SDPOZN-2805-fix-cve-issues / в репозитории плагина Ranger (✓). Пересборка их закрывает.
- **P2 (реально открыто и достижимо):** `request smuggling` в веб-UI Jetty 9.4.57 (CVE-2026-2332). Исправления под Java 8 в OSS нет — митигировать на уровне `service-mesh` либо принять с документированием.
- **P3 (открыто, но не эксплуатируется):** `commons-configuration2` → 2.15.0, `commons-lang3` → 3.18.0, `zookeeper` → 3.8.6 (только `httpfs`), `nimbus` → 9.37.4; `dnsjava` (заблокировано → Hadoop 3.4.x) и `hadoop-common` (→ 3.4.x); а также вендорские `httpClient`/`htrace` плагина Ranger, неактивные без включённой авторизации Ranger. Подавить с применимой сноской либо обновить при случае.

Примечание: очевидные опечатки OCR в исходном скане исправлены (VE-2026-.../VE-2024-... → CVE-..., кириллическая С → c, слипы CRITICAL/commons-configuration2 2.20.1). Ссылки на бюллетени без CVE (`jackson-core` GHSA-72hv-8253-57qq) оставлены как есть. Статус исправления указан по закоммиченному POM ветки SDPOZN-2805-fix-cve-issues (дистрибутив на диске пересобирался не после каждого обновления); достижимость — из дескрипторов `classpath` дистрибутива + `ozone-default.xml`.